

NAF

PROJECT STATUS REPORT

NAF Reklamasjons-system

A consolidated view of delivered capabilities, security posture, identified risks, and the opportunity roadmap ahead.

Prepared by	Tom Aylward
Date	25 April 2026
Audience	Project lead (personal reference)
Classification	Confidential — Internal NAF use

CONTENTS

Table of Contents

01	Executive Summary	3
02	Project Overview	4
03	Architecture & Technology	5
04	Delivered Capabilities	6
05	Security Posture	8
06	Risk Register	10
07	Opportunity Roadmap	12
08	Parked Initiatives	14
09	Open Decisions	16
10	Vendors & Costs	17
11	Operating Model	18

01 · EXECUTIVE SUMMARY

Where the project stands today

HEADLINE

NAF Reklamasjonssystem is in production with five core capabilities live, a security posture aligned to NAF.no enterprise standards, and a clear runway of low-risk improvements ahead. The system is ready for IT security review pending two final compliance work-streams.

What has been built

A web-based complaint-handling tool that lets NAF customers submit complaints, exchange messages with a saksbehandler, and attach files — without creating an account. Internally, saksbehandlere work cases scoped to their own centre, senterledere oversee their region, and administrators manage users and exports. Five distinct features have been shipped to production, each with implementation plans, code reviews, and security checks documented.

Security position

A full-spectrum security hardening sprint has just been completed. All eight modern security headers are in place and verified live. Distributed rate limiting is operational on three public endpoints. A dependency vulnerability was identified and resolved by replacing the affected library. A formal *SECURITY.md* document and a *security.txt* responsible-disclosure file are published. The platform meets or exceeds NAF.no's own externally measurable security standards.

What's next

Two work-streams complete the IT security readiness arc — an access-control audit and a GDPR / data-handling documentation pass. Together these are estimated at one working week. Beyond compliance, a lightweight keyword search over resolved cases offers high near-term value to saksbehandlere at minimal cost. A more ambitious semantic-search capability has been deliberately parked until the resolved-case corpus reaches the depth required to make it useful.

Top three risks under management

1. **Free-tier infrastructure dependency.** Supabase pauses inactive projects after seven days on the free plan; storage is also capped at 1 GB. Mitigation: upgrade to Pro before active production use scales.

2. **Direct-to-production deployment habit.** Current workflow pushes straight to *main*. Mitigation: adopt branch + preview-URL + pull-request discipline starting with the next change.
3. **Single-developer continuity (bus-factor of one).** Mitigation: comprehensive documentation — including this report — reduces but does not eliminate this exposure.

02 · PROJECT OVERVIEW

What the system does and who it serves

IN ONE SENTENCE

A purpose-built complaint-handling platform that gives NAF customers a frictionless way to submit and reply to complaints, while giving saksbehandlere a structured, role-scoped workspace to manage them.

Users and their workflows

Role	Primary tasks
Customer	Submits a new complaint via the public form, then replies to follow-up questions through a tokenised email link — no login required.
Saksbehandler	Works the case queue scoped to their own centre. Sends replies, uploads attachments, applies templates, escalates when needed.
Senterleder	Sees all cases within their centre. Read-oriented oversight role.
Administrator	Approves new saksbehandler registrations, has full case visibility, generates Excel exports.

Production environment

Live URL	naf-reklamasjon-next.vercel.app
Hosting domain	Vercel (NAF subdomain not currently available)
Data residency	European Union (Stockholm region for primary data store)
Status	Production, low-volume operational use

Why this report exists

This document is the canonical reference for the project's current state. It is intended for the project lead to maintain situational awareness over time, to brief any future contributors, and — with light editing — to support an IT security review conversation when the moment arrives. The Markdown source lives in the repository at docs/PROSJEKT0VERSIKT.md and similar; this PDF is a moment-in-time snapshot.

03 · ARCHITECTURE & TECHNOLOGY

How the system is built

ARCHITECTURAL POSTURE

A modern, server-first Next.js application backed by Supabase, with security enforced at the database layer rather than only in application code. Stack choices favour managed services with EU data residency to minimise both operational burden and compliance surface area.

Technology stack

Layer	Technology
Frontend & backend	Next.js 16 (App Router) in TypeScript; React Server Components
Database	Supabase PostgreSQL (Stockholm) with Row Level Security
Authentication	Supabase Auth — JWT in httpOnly cookies, no client-side token storage
File storage	Supabase Storage with signed URLs (60-minute expiry)
Transactional email	SendGrid
Rate limiting	Upstash Redis (sliding-window algorithm, EU region)
Hosting	Vercel — auto-deploy from <i>main</i> branch
Excel export	ExcelJS (replaced the vulnerable <i>xlsx</i> library)

Architectural principles

- 1. Database-enforced authorisation.** Row Level Security policies in Supabase ensure saksbehandlere can only read cases tied to their own centre — even if application code contained a bug. Authorisation is not a single point of failure.
- 2. Service-role isolation.** The Supabase service-role key is used exclusively in server contexts and is never bundled to the browser. Public client code uses the anonymous key.
- 3. Server-first rendering.** Wherever possible, logic runs on the server through React Server Components. This shrinks the JavaScript shipped to clients and reduces the surface area for client-side attacks.

4. **Tokenised public access.** The customer reply portal uses 122-bit UUID tokens validated server-side with timing-safe comparison. No customer authentication is required, but enumeration attacks are not feasible.

04 · DELIVERED CAPABILITIES

Five features in production

CAPABILITY SUMMARY

Five distinct capabilities have been shipped, each spec-driven and code-reviewed. Together they form a complete, end-to-end complaint-handling workflow with the safeguards expected of a system handling personal data.

Capability 1 — Roles, RLS & escalation

The foundation. A three-tier role model — administrator, saksbehandler, senterleder — enforced at the database through Row Level Security. Saksbehandlere see only cases tied to their centre; this is unbypassable from the application layer. Includes search, pagination, escalation notifications, reply templates, and basic reporting.

Capability 2 — User registration & admin

Self-service registration for new saksbehandlere with an explicit approval gate. New users register and wait; an administrator approves or rejects via the admin console. Email notifications are dispatched at each state change. The administrator interface lives at /admin.

Capability 3 — File attachments

Customers and saksbehandlere can attach JPG, PNG, and PDF files — bounded at 10 MB per file and five files per upload. Files are persisted in Supabase Storage and accessed exclusively through signed 60-minute URLs. The attachments table is itself protected by Row Level Security policies, so attachment access mirrors case access.

Capability 4 — Customer reply portal

Outbound emails carry a "Svar på reklamasjonen" button that links to a public portal at /svar/[case_id]?token=UUID. Customers can write a reply and attach a file without logging in. Replies surface in the case timeline in real time and trigger an email notification to the assigned saksbehandler. The token is validated server-side with timing-safe comparison; the same response is returned for missing cases and wrong tokens to prevent enumeration.

Capability 5 — Security hardening

A dedicated sprint that brought the platform up to NAF.no security standards. Components shipped:

- **Security headers** — CSP, HSTS (two years with preload), X-Frame-Options, X-Content-Type-Options, Referrer-Policy, COOP, CORP, Permissions-Policy. All eight verified live in production.
- **Distributed rate limiting** — Upstash Redis with sliding window. Customer reply: 5 requests per 10 minutes. File upload: 10 per 10 minutes. New complaint submission: 3 per hour. Verified end-to-end in production.
- **Dependency audit** — the vulnerable *x/sx* library was replaced with *exceljs*, resolving a HIGH-severity CVE. Two MODERATE CVEs remain in transitive dependencies, both documented and accepted.
- **Responsible disclosure** — `security.txt` published at `/.well-known/security.txt`.
- **Audit-ready documentation** — an eight-section *SECURITY.md* covering data inventory, vendors, authorisation, controls, limitations, and the dependency audit, written for a professional reviewer.

05 · SECURITY POSTURE

Controls in place

POSTURE SUMMARY

The platform is hardened across nine layers of defence — from transport security to dependency hygiene — and is positioned to achieve a Grade A rating on industry-standard external scanners. Two acknowledged limitations are documented as future enhancements rather than gaps.

Defence in depth

Layer	Control
Transport	HTTPS only; HSTS for two years with subdomain inclusion and preload eligibility; automatic upgrade of insecure requests.
Browser headers	Full Content Security Policy without wildcards; X-Frame-Options DENY; COOP same-origin; CORP same-site; Permissions-Policy disabling camera, microphone, geolocation, payment, USB, and display capture.
Authentication	Supabase JWT in httpOnly cookies. No tokens stored in browser local storage.
Authorisation	Row Level Security on all tables; centre scoping enforced for saksbehandlere at the database layer.
Rate limiting	Upstash Redis distributed counters with sliding window. Fail-open posture preserves availability if Upstash itself fails.
Input validation	Length limits, file-type and file-size enforcement, HTML escaping in all email templates.
File storage	Signed URLs with 60-minute expiry; Row Level Security on the <i>attachments</i> table.
Public access	UUID tokens with 122-bit entropy; timing-safe comparison; same response for invalid token and missing case.
Dependencies	Clean of HIGH and CRITICAL vulnerabilities; remaining MODERATE findings documented and accepted.

External scanner expectation

The platform is expected to score Grade A on securityheaders.com. Achieving Grade A+ requires moving from the current 'unsafe-inline' CSP to a nonce-based policy — a known enhancement, scoped but not yet implemented.

Acknowledged limitations

- **NAF subdomain not yet available.** The system runs on *vercel.app*. This is a brand and trust limitation rather than a technical security weakness; revisit if NAF IT can later assign a subdomain.
- **No web application firewall.** The platform relies on Vercel's platform-level protection. A dedicated WAF can be added if traffic volume or threat profile justifies the operational cost.
- **CSP uses 'unsafe-inline' for scripts.** Required for Next.js client-side hydration without nonce injection. Path to a stricter nonce-based policy is documented in *SECURITY.md*.

06 · RISK REGISTER

What could go wrong, and how it is being managed

RISK POSTURE

Twelve risks tracked. The two most material are operational rather than security-related: free-tier infrastructure pause-out and the absence of staging-grade database isolation. Both have known, low-cost mitigations triggered by an active-use threshold.

Tracked risks

Risk	Likelihood	Impact	Mitigation
Supabase free-tier project pauses after 7 days idle	HIGH	HIGH	Upgrade to Supabase Pro before active production use scales.
Free-tier 1 GB storage limit reached	MEDIUM	MEDIUM	Upgrade to Pro; introduce attachment retention policy.
Database migration locks production table	MEDIUM	MEDIUM	Use <i>CREATE INDEX CONCURRENTLY</i> ; run off-hours; manual backup before migration.
Direct-to-main deployment ships a defect to live customers	MEDIUM	HIGH	Adopt feature-branch + preview-URL + pull-request workflow effective immediately.
Vercel.app domain perceived as non-official	MEDIUM	MEDIUM	Re-engage NAF IT for subdomain assignment when feasible; emphasise official sender in customer emails.
SendGrid bounce rate climbs	LOW	MEDIUM	Monitor sender reputation; verify SPF and DKIM if rates spike.
'unsafe-inline' CSP exploited if another vulnerability exists	LOW	MEDIUM	Move to nonce-based CSP when a hardening sprint allows.
Newly disclosed CRITICAL CVE in a dependency	MEDIUM	HIGH	Monthly <i>npm audit</i> ; subscribe to GitHub Dependabot alerts.
Malicious file uploaded as attachment	LOW	MEDIUM	File-type and size validation in place; consider antivirus scanning if volume warrants.
Single-developer continuity (bus-factor of one)	HIGH	HIGH	Comprehensive documentation including this report; onboarding-ready repository.
Customer submits more PII than required	HIGH	MEDIUM	Privacy notice; short retention policy; data minimisation in any future analytics.
Third-party vendor incident affects availability	LOW	MEDIUM	Status-page monitoring; documented vendor list in SECURITY.md.

07 · OPPORTUNITY ROADMAP

What to build, in what order

SEQUENCING LOGIC

The next quarter prioritises closing the security review loop and removing free-tier risk. Net-new user-facing capabilities follow only once the foundations are settled. A more ambitious AI-driven feature is held until the underlying data corpus is deep enough to make it useful.

Near term — close the security loop

#	Initiative	Effort	Why it matters
1	Access-control audit	~2 days	Verify RLS policies are end-to-end enforced; add admin audit log. Locks in what is already built before adding more.
2	GDPR & data-handling documentation	~2–3 days	Data residency confirmation, retention policy, vendor DPAs, customer privacy notice. Required for IT security review.
3	Lightweight keyword search over resolved cases	~1–2 days	Useful immediately; builds the corpus and the workflow muscle memory needed for a future semantic-search feature.

When active use begins

#	Initiative	Effort	Why it matters
4	Supabase Pro upgrade	~1 hour	Removes pause-out risk; enables Branching for safer migrations; raises storage limit.
5	Branch + preview + PR workflow	Processes	Zero-cost workflow change that prevents the majority of ship-and-regret moments.

Longer horizon

#	Initiative	Effort	Why it matters
6	Semantic search on re-solved cases	~3–4 days	Surfaces precedent for consistency; held until corpus reaches ~200 resolved cases.
7	Nonce-based CSP	~1 day	Lifts external scanner score from A to A+; closes the last documented header limitation.
8	NAF subdomain	NAF IT-led	Strengthens customer trust signals; depends on internal assignment process.
9	Web application firewall	Vendor-led	Adds attack-surface protection beyond Vercel's platform layer; warranted at higher traffic.
10	Explicit "similar case" signal at resolution	~½ day	Hard data on case repeatability over three months; informs whether semantic search is worth building.

Aspirational

1. **AI-drafted reply suggestions** — built on top of semantic search plus an LLM; suggests a draft the saksbehandler edits.
2. **Customer status page** — lets customers check case status without waiting for email.
3. **Senterleder dashboard** — case volume, average response time, escalation trends.
4. **NAF membership lookup** — surface member context directly in the case view.

08 · PARKED INITIATIVES

Ideas considered and explicitly deferred

DISCIPLINE

Two well-developed ideas have been deliberately parked rather than built. Each has a written rationale, a documented trigger condition for re-opening, and a preserved design — protecting the option without paying its cost today.

Parked: Semantic search on resolved cases

What it would do. When a saksbehandler opens a complaint, surface three past resolved cases that are semantically similar — based on the meaning of the text, not just keyword overlap. Each match would display the original complaint, NAF's reply, and a one-click "Copy reply" button.

Why parked. Vector similarity needs corpus depth (around 200 resolved cases) to feel useful. Existing reply templates already cover much of the consistency need. Adding OpenAI as a fourth third-party vendor introduces new compliance overhead. There is also a behavioural risk that one-click reply copying degrades answer quality if applied uncritically.

Trigger to revisit. Any one of: corpus exceeds ~200 resolved cases; saksbehandlere repeatedly report inability to find prior similar cases; consistency audits show recurring divergence; reply templates begin to feel insufficient at scale.

Design preserved. Inline placement between complaint and reply; automatic on case open; expandable cards with reply preview; OpenAI *text-embedding-3-small* model with EU residency. Full design in docs/future-work/2026-04-25-similar-cases-vector-search.md.

Parked: Permanent staging environment

What it would do. Provide true production-mirrored isolation for testing — separate Supabase project, separate vendor accounts, code promoted through a staging branch before production.

Why parked. The current scale of the project does not justify the operational overhead. Vercel preview URLs already provide code-level isolation, and Supabase Branching offers database-level isolation as a low-effort upgrade when needed. Building a permanent staging environment now would solve a problem we don't yet have.

Trigger to revisit. First material database change, multiple developers joining the project, or an explicit IT-security requirement for a staging mirror.

Path forward. Adopt branch-and-preview discipline now (no infrastructure cost). Upgrade to Supabase Pro and enable Branching when active use begins (~\$25/month). Build a permanent

staging environment only if scale demands it.

09 · OPEN DECISIONS

What needs an answer, and from whom

DECISION POSTURE

Eight unresolved decisions, none blocking current operations. Three are tied to the upcoming compliance work-streams and will be settled as part of that work. The remainder are strategic choices that mature with experience.

Question	Owner	Trigger
Should the system get a NAF subdomain?	NAF IT	When IT capacity allows
Upgrade Supabase to Pro now or later?	Project lead	First material DB change or active-use ramp
Case retention period — how long should resolved cases be kept?	Privacy / Legal	GDPR work-stream
Who signs DPAs with Supabase, Vercel, SendGrid, Upstash?	Legal	GDPR work-stream
Adopt a permanent staging environment?	Project lead	Multiple developers or IT-security requirement
Send complaint confirmation by SMS in addition to email?	Product	Customer feedback
When to schedule the formal IT security review?	Project lead	After GDPR work-stream completes
Should customers be able to download a case summary as PDF?	Product	Volume / customer request

10 · VENDORS & COSTS

What we depend on and what it costs

COST POSTURE

The platform currently runs on free-tier infrastructure — total marginal monthly cost zero. Anticipated steady-state cost at active production use is approximately fifty to seventy US dollars per month, scaling linearly with volume.

Vendors in use today

Vendor	Role	Plan
Vercel	Application hosting; serverless functions; preview deployments per branch	Hobby (free)
Supabase	PostgreSQL database; authentication; file storage	Free
SendGrid	Transactional email delivery	Free (100 / day)
Upstash	Redis for distributed rate limiting (EU region)	Free (10k requests / day)

Anticipated upgrade costs

Trigger	Action	Recurring cost
Active production use begins	Supabase Pro upgrade — removes pause risk, raises storage, enables Branching	USD 25 / month
Volume exceeds 100 emails / day	SendGrid Essentials	From USD 20 / month
Team expands or traffic grows	Vercel Pro (per seat)	USD 20 / month
Semantic-search feature is opened	OpenAI embeddings — one-time backfill plus marginal use	~USD 1 / month

Total cost outlook

Today (free tier)	USD 0 / month
Active steady-state (estimated)	USD 50–70 / month
Cost-to-revenue framing	Negligible relative to the saksbehandler operational time the platform replaces.

11 · OPERATING MODEL

How the project is run

HOW WORK HAPPENS

A spec-driven, subagent-assisted development workflow that produces structured documentation as a byproduct of building. Every feature has a design specification, an implementation plan, and a code-review record, which is what makes a report like this one possible at all.

Development workflow

1. **Brainstorm** — design specification written to docs/superpowers/specs/
2. **Plan** — implementation plan written to docs/superpowers/plans/
3. **Implement** — subagent-driven development with spec compliance and code-quality reviews per task
4. **Deploy** — feature branch → preview URL → pull request → merge to *main* → production (workflow recently formalised)

Documentation hierarchy

Document	Purpose
<i>SECURITY.md</i>	Security posture, controls, vendor list, dependency audit. Audience: IT security reviewer.
<i>docs/README.md</i>	Index of features built and links to specs, plans, future work.
<i>docs/superpowers/specs/</i>	Per-feature design specifications.
<i>docs/superpowers/plans/</i>	Per-feature step-by-step implementation plans.
<i>docs/future-work/</i>	Parked initiatives, with rationale and trigger conditions for re-opening.
<i>docs/PROSJEKTOVERSIKT.md</i>	Norwegian living overview; companion to this English report.
This report	Snapshot view of the project for the project lead's reference.

Maintenance of this report

This document is regenerated from a structured source on demand. Updates are warranted when a new feature reaches production, when a tracked risk materially changes, when an open decision is resolved, or when a new vendor or cost item enters the picture.

— E N D O F R E P O R T —